TECHNOVA SOLUTIONS PVT. LTD.
ACCESS CONTROL POLICY

Document ID	TN-ADM-POL-002
Document Type	Administration / Access Control Policy
Document Owner	Administration Department / Information Security
Approving Authority	Managing Director
Classification	Internal — Confidential
Version	1.0
Effective Date	01 April 2026
Review Cycle	Annual
Status	Active
Supersedes	New Policy

1. Purpose

This Access Control Policy establishes the requirements TechNova Solutions Pvt. Ltd. (“TechNova” or “the Company”) uses to ensure that access to information, applications, systems, devices, facilities, and services is authorized, appropriate, traceable, and promptly removed when no longer required.

The policy supports least privilege, segregation of duties, accountability, and protection of Company information.

2. Scope

This policy applies to employees, contractors, consultants, temporary personnel, suppliers, service accounts, privileged accounts, applications, systems, infrastructure, cloud services, databases, networks, facilities, and other resources requiring controlled access.

3. Access Control Principles

- Least privilege
- Need-to-know
- Role-based access
- Unique identity and accountability
- Separation of duties
- Default-deny where appropriate
- Periodic review
- Timely provisioning and deprovisioning
- Traceability and auditability

4. Access Ownership

Every controlled system and information resource must have an accountable owner. Owners determine appropriate access, approve requests within their authority, and periodically review whether access remains necessary.

5. User Identity

Users should be provided unique identities wherever technically feasible. Shared accounts should be avoided and may be permitted only when technically necessary and appropriately controlled.

Accountability must be maintained for actions performed through privileged or shared mechanisms.

6. User Lifecycle

- Joiner — provision approved access.
- Mover — adjust access when role or responsibilities change.
- Leaver — revoke access promptly when employment or authorization ends.
- Periodic review — validate continued need for access.

7. Access Request

Access must be requested through an approved process and should identify the user, resource, role or permission requested, business justification, duration where applicable, and required approval.

Access must not be granted solely on verbal or informal requests when the approved workflow requires documented authorization.

8. Access Approval

Access approval must come from an authorized manager, resource owner, system owner, or other designated authority appropriate to the sensitivity and privilege level requested.

9. Role-Based Access

Where practical, access should be assigned through predefined roles aligned with job responsibilities. Direct individual permissions should be minimized when an approved role provides the appropriate level of access.

10. Least Privilege

Users and services must receive only the permissions necessary to perform authorized responsibilities.

- Avoid unnecessary administrator rights.
- Remove obsolete permissions.
- Use temporary elevation where appropriate.
- Review high-risk permissions more frequently.

11. Need-to-Know

Access to confidential or restricted information must be limited to personnel with a legitimate business need. Job title alone does not establish entitlement to sensitive information.

12. Authentication

Approved authentication mechanisms must be used to verify user identity before access is granted.

- Strong authentication for sensitive systems
- Multi-factor authentication where required
- Protection of authentication secrets
- Account lockout or protective controls where appropriate

13. Passwords and Secrets

Passwords, tokens, keys, certificates, and other authentication secrets must be protected from disclosure and stored only in approved mechanisms.

- Do not share credentials.
- Do not place secrets in source code.
- Do not send credentials through insecure channels.
- Report suspected compromise immediately.

14. Multi-Factor Authentication

MFA should be required for privileged, remote, administrative, and sensitive access where designated by Information Security or system owners.

MFA methods must themselves be protected and managed according to approved security requirements.

15. Privileged Access

Privileged access provides elevated capabilities and must be strictly controlled.

- Limit privileged accounts.
- Use separate privileged identities where required.
- Approve privileged access explicitly.
- Log relevant privileged activity.
- Review privileged access periodically.
- Remove privileged access immediately when no longer required.

16. Emergency Privileged Access

Emergency or break-glass access may be provided when necessary to protect critical services or resolve serious incidents. Such access must be controlled, logged, time-limited where feasible, and reviewed after use.

17. Service Accounts

Service accounts used by applications, integrations, automation, or infrastructure must have identifiable ownership and only the permissions required for their function.

- Use non-interactive access where appropriate.
- Protect service credentials.
- Rotate credentials according to risk and technical capability.
- Disable unused service accounts.

18. API Keys and Tokens

API keys, tokens, and similar credentials must be issued only when required, stored securely, scoped appropriately, and revoked when no longer required or when compromise is suspected.

19. Temporary Access

Temporary access must have a defined purpose and, where practical, an expiration date. Extensions require renewed authorization.

20. Third-Party Access

Supplier and contractor access must be limited to approved resources and the minimum permissions necessary.

- Named users where feasible
- Defined business purpose
- Contractual/security requirements

- Time-limited access where appropriate
- Prompt revocation when work ends

21. Remote Access

Remote access must use approved secure mechanisms and comply with authentication, endpoint-security, network-security, and information-handling requirements.

22. Network Access

Network access should be segmented and controlled based on trust, system sensitivity, and business need. Administrative access to network infrastructure must be restricted to authorized personnel.

23. Application Access

Application permissions must align with business responsibilities and approved roles. Sensitive functions should require appropriate authorization and, where necessary, additional verification.

24. Database Access

Direct database access should be limited to authorized technical personnel and service accounts that require it. Application-level access should be preferred for ordinary business operations where appropriate.

25. Cloud Access

Cloud resources must use controlled identities and permissions. Privileged cloud access should be limited, monitored, and reviewed.

26. Source Code Access

Access to source repositories must be based on project responsibility and business need.

- Restrict protected branches.
- Limit repository administration.
- Remove access when project responsibilities end.
- Protect repositories containing sensitive code or configuration.

27. Production Access

Production access must be more restrictive than development or test access. Personnel should use production privileges only when required for authorized work.

Where practical, production administrative activity should use controlled, auditable mechanisms.

28. Development and Test Access

Development and test environments must not provide unnecessary access to production data or production credentials.

Sensitive production information should not be copied into lower environments unless specifically authorized and appropriately protected.

29. Access to Personal Information

Access to employee, customer, supplier, or other personal information must be limited to authorized purposes and personnel with a legitimate business need.

30. Segregation of Duties

Access should be designed so that incompatible responsibilities are separated where required to reduce fraud, error, unauthorized changes, or conflicts of interest.

- Request versus approval
- Development versus production approval
- Payment preparation versus payment approval
- Access administration versus access review

31. Access Review

System and data owners should periodically review access to confirm that permissions remain appropriate.

- Users who changed roles
- Departed users
- Inactive accounts
- Privileged accounts
- Third-party accounts
- High-risk permissions

32. Access Review Evidence

Reviews should produce sufficient evidence to demonstrate who reviewed access, what was reviewed, decisions made, and remediation required.

33. Dormant Accounts

Accounts that are inactive beyond defined operational periods should be disabled or reviewed according to system requirements and risk.

34. Account Locking

Systems should use appropriate protective controls against repeated failed authentication attempts, credential attacks, and other unauthorized access attempts.

35. Access Revocation

Access must be revoked promptly when authorization ends.

- Employment separation
- Contract completion
- Role change
- Project completion
- Access no longer required
- Security or policy violation

36. Employee Separation

Managers, HR, system owners, and technical teams must coordinate to ensure access is removed in accordance with the Company's exit and user-lifecycle processes.

37. Role Changes

When responsibilities change, old permissions must be reviewed and removed where no longer required. New permissions must be separately authorized.

38. Access Conflicts

Access requests that create a conflict of interest or segregation-of-duties concern must be escalated for review before access is granted.

39. Access Logging

Security-relevant authentication and authorization events should be logged where appropriate.

- Successful and failed authentication
- Privileged activity
- Administrative changes
- Access-policy changes
- Significant authorization events

40. Log Protection

Access logs must be protected against unauthorized alteration and access. Retention must follow applicable operational, security, and data-retention requirements.

41. Monitoring

Information Security and system owners may monitor access activity to detect suspicious behavior, policy violations, excessive privileges, or unauthorized access.

42. Access Anomalies

Unusual access patterns, unexpected privilege changes, repeated authentication failures, or access from suspicious contexts should be investigated according to risk.

43. Unauthorized Access

Suspected unauthorized access must be reported immediately and handled according to the Incident Response and Information Security requirements.

- Contain the access.
- Preserve relevant evidence.
- Review affected accounts and resources.
- Revoke or reset compromised credentials.
- Assess impact and required notifications.

44. Credential Compromise

Users must report suspected password, token, key, or authentication compromise immediately. Authorized responders may revoke, rotate, or invalidate affected credentials.

45. Access During Incidents

Incident response may require temporary elevated access. Such access must remain limited, authorized, and auditable even during an emergency.

46. Physical Access

Access to offices, restricted rooms, equipment areas, and other controlled facilities must be granted according to business need and physical-security requirements.

47. Visitor Access

Visitors must not receive unrestricted access to controlled areas or systems. Visitor access should be authorized, limited, and supervised where appropriate.

48. Device Access

Company devices must use appropriate authentication and security controls. Users must not disable required controls to make access easier.

49. Mobile Access

Mobile access to Company systems must use approved authentication and device-security controls. Lost or stolen devices must be reported promptly.

50. External Sharing

Access to shared drives, collaboration platforms, documents, or other resources must be restricted to intended recipients and reviewed when sharing arrangements change.

51. Public Links

Public or anonymous access mechanisms must not be used for confidential or restricted Company information unless explicitly authorized and protected by appropriate controls.

52. Access Provisioning

Provisioning should be performed through approved administrative processes with sufficient records to establish authorization, requested permissions, approver, and completion.

53. Access Administration

Personnel administering access must use authorized administrative accounts and follow change and security requirements. Administrative actions should be traceable.

54. Access Requests for Sensitive Systems

Sensitive systems may require additional approvals, stronger authentication, additional logging, or more frequent review based on risk.

55. High-Risk Access

Access to security infrastructure, financial systems, production environments, identity systems, sensitive data, and administrative consoles should receive enhanced controls appropriate to risk.

56. Access Exceptions

Exceptions to standard access controls require documented justification, defined duration, compensating controls where appropriate, and approval from the designated authority.

57. Access and Business Continuity

Continuity arrangements must provide necessary access to critical services without creating uncontrolled privileges. Emergency access should be reviewed after continuity operations end.

58. Access and Asset Management

When devices or other assets are assigned, transferred, recovered, or retired, associated access should be reviewed to prevent unauthorized continued access.

59. Access and Data Retention

Access to retained information must remain restricted according to its classification and business need. Retention of information does not imply unrestricted access.

60. Compliance and Violations

Violations may result in access suspension, investigation, disciplinary action, contractual action, or other appropriate measures.

Intentional unauthorized access, credential sharing, privilege misuse, or circumvention of access controls may be treated as serious violations.

61. Frequently Asked Questions

Why can't I use a colleague's account?

Unique identities support accountability and prevent actions from being incorrectly attributed to another person.

Why do I need approval for access?

Approval confirms that access is required for a legitimate business purpose and is appropriate for the requested resource.

What happens when I change departments?

Existing access should be reviewed and unnecessary permissions removed before or as part of the role change.

How quickly is access removed after departure?

Access should be revoked promptly according to the Company's user-lifecycle and exit requirements.

Can temporary access be granted?

Yes, when necessary and authorized. It should have a defined purpose and expiration where practical.

Who approves privileged access?

The designated system or resource owner and other required authorities based on the sensitivity and privilege involved.

What should I do if I suspect my password was compromised?

Report it immediately and follow the approved credential-reset or containment process.

Can production access be used for normal development?

Production access should be restricted to authorized operational needs and should not be used unnecessarily.

What is least privilege?

It means giving a user, application, or service only the permissions needed to perform its authorized function.

Are third parties covered by access control?

Yes. Third-party access must be authorized, limited, monitored where appropriate, and revoked when no longer required.

62. Revision History

Version	Effective Date	Description	Owner	Approval
1.0	01 April 2026	Initial release of Access Control Policy	Administration / Information Security Dir	Managing Director

63. Related Documents

- Information Security Policy
- Data Retention Policy

- Disaster Recovery Policy
- Business Continuity
- Incident Response
- Asset Management
- Employee Handbook
- Exit Policy
- Engineering Handbook
- Testing Standards

END OF DOCUMENT

TN-ADM-POL-002 | Version 1.0 | Internal — Confidential | Administration / Information Security